



STEELTRACE

Security deep dive



Previous

> Current sprint20+⚙️

Password change, passwords don't match
bug
#438

A test may not be assigned to a laboratory, but performed by the manufacturer
To Do chevron-tenaris
#386

> Work in progress60+⚙️

Migrate old Total certificate to new Environment
#382

Magnetic particle examination
#398

Change TOTP to use an app
#436

History link broken on incoming order
bug
#431

Supplier not visible at incoming order screen
bug
#430

Hardness test on 4 quadrants + suggestion for new interface of hardness test
To Do chevron-tenaris
#396

> Pull request30+⚙️

Face ID - Finger Print ID
#284

Tensile test - custom requirements + API 5L requirements missing
To Do chevron-tenaris
#389

Impact test - API 5L + customization suggestions
To Do chevron-tenaris
#391

> Ready for test30+⚙️

Expand order capability to handle both incoming and outgoing orders.
#321

Supplier not selected on edit screen
bug
#432

Feedback Mnemonic missing when recovering (but process also very labor intensive)
bug
#428

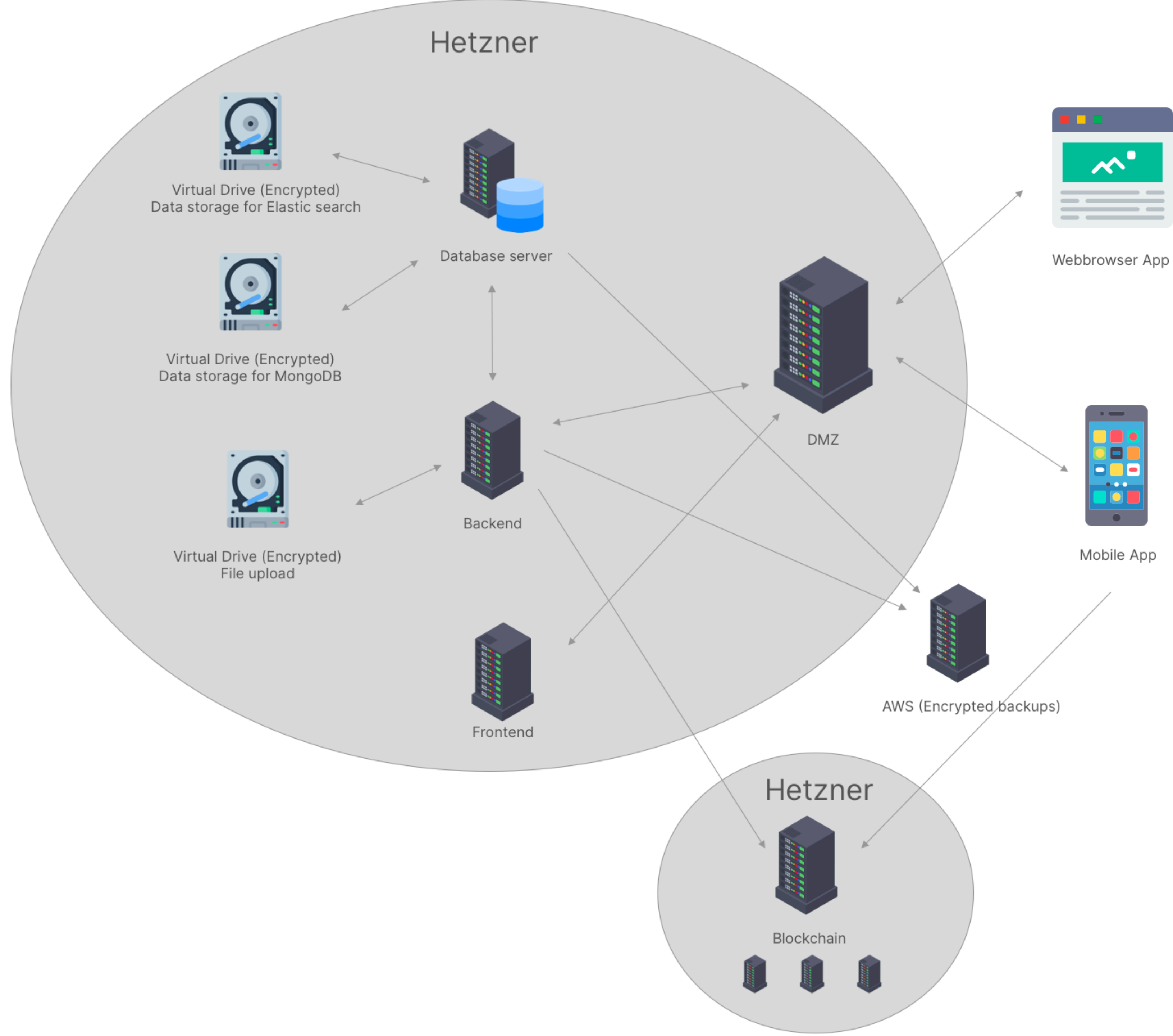
Status

The screenshot displays a Jira board with four columns representing different stages of a workflow. Each column has a header bar with a title, a count of items, and icons for adding and configuring items.

- Current sprint** (0 items): This column is currently empty.
- Work in progress** (6 items): This column contains five task cards:
 - Migrate old Total certificate to new Environment** (#382) assigned to a user with a grey status icon.
 - Add new fields to "certificates" issued by the laboratory** (#451) assigned to a user with a grey status icon.
 - Magnetic particle examination** (#398) with a green status icon and assigned to a user.
 - Change TOTP to use an app** (#436) with a green status icon.
 - Hardness test on 4 quadrants + suggestion for new interface of hardness test** (#396) with a "To Do" label, assigned to chevron-tenaris, and a green status icon.
 - A test may not be assigned to a laboratory, but performed by the manufacturer** (#386) with a "To Do" label, assigned to chevron-tenaris, and a yellow status icon.
- Pull request** (1 item): This column contains one task card:
 - Face ID - Finger Print ID** (#284) with a green status icon.
- Ready for test** (2 items): This column contains two task cards:
 - Proofload test crashes on saving** (#449) with a red "bug" label and a green status icon.
 - Expand order capability to handle both incoming and outgoing orders.** (#321) with a green status icon and assigned to a user.

Where we are

- ◉ Monitoring in place -> Zabbix with live alerts
- ◉ Secure data center with DDOS protections / Firewalls
- ◉ NDA's with all employees
- ◉ Limited access to customer data to a few key employees
- ◉ DMZ infrastructure
- ◉ SSH: Public / Private key only access
- ◉ Testing plans
- ◉ One off site (AWS) backup location / one at Hetzner
- ◉ Encrypted data at rest
- ◉ HTTPS connections only
- ◉ 2FA using e-mail (auth app coming in next deploy)
- ◉ Deploy via CI/CD
- ◉ Unit testing



Topology Map

Where we need to improve

- ◉ Monitor server access by employees
- ◉ QM plan with risk based approach
- ◉ ISO 27001 Certifications
- ◉ SOC3 compliance
- ◉ Deploy multi signature infrastructure for the blockchain
- ◉ Expand the number of blockchain nodes
- ◉ More off site backups
- ◉ Documentation of processes
- ◉ Tracking of actions taken

Monitoring



- Password changes
- Security updates
- Server resources
- Firewall changes
- Container health
- Virus scanner database age
- Tracking actions by dev ops
- Documenting processes

Monitoring

Time ▾	☐ Severity	Recovery time	Status	Info	Host	Problem
09:32:23 AM	☐ Warning		PROBLEM		Staging	⬇ Docker: Container signerapp: Not running
09:26:16 AM	☐ Information	09:29:25 AM	RESOLVED		Staging	Docker: Version has changed (new version: 20.10.7) ?
09:26:15 AM	☐ Warning		PROBLEM		Staging	⬇ Docker: Container frontend_portal: Not running
09:25:36 AM	☐ Warning		PROBLEM		Staging	
09:25:33 AM	☐ Warning		PROBLEM		Staging	
09:25:29 AM	☐ Warning		PROBLEM		Staging	
Today						
021 03:46:17 PM	☐ Average		PROBLEM		Staging	
021 03:23:39 PM	☐ Warning		PROBLEM		Staging	
July						
021 08:49:14 AM	☐ Warning		PROBLEM		Staging	
021 08:26:05 AM	☐ Average		PROBLEM		Staging	

Update problem

Problem 7 problems selected.

Message

Due to security updates, has been resolved.
Action taken: Added restart always to docker compose

Scope

☒ Only selected problems 7 events
☐ Selected and all other problems of related triggers 7 events

Change severity

☐ Not classified ☐ Information ☐ Warning ☐ Average ☐ High ☐ Disaster

Acknowledge

☐

Unacknowledge

☐

Close problem

☐

* At least one update operation or message must exist.

Update

Cancel

Hosting

HETZNER

- Data centers in Germany and Finland
- GDPR complaint
- DDOS protection
- Access controlled cages: internal process within ISMS and electronic keys with logging of user-actions
- On-site paid inspection possible
- The provider utilizes CCTV and motion detection

AWARDS



Bayerns Best 50



ECO Award



ISO 27001-Certification



Readers' Choice 2020



Readers' Choice 2019



Readers' Choice 2018

Appendix 2 of the Agreement Pursuant to Art. 28 GDPR: Technical and Organizational Measures in Accordance with Art. 32 GDPR and Amendments

I. Confidentiality

• Physical access control

- **Data center parks in Nueremberg, Falkenstein and Helsinki**
 - electronic physical entry control system with log
 - high security perimeter fencing around the entire data center park
 - documented distribution of keys to employees and colocation customers for colocation racks (each Client only for his rack)
 - policies for accompanying and designating guests in the building
 - data center staff present 24/7
 - video monitoring at entrances and exits; security door interlocking systems and server rooms
 - For people outside of the employment of Hetzner Online GmbH (data center visitors), entrance to the building is only permitted in the company of a Hetzner Online employee.

• Monitoring

- electronic physical access control system with log
- video surveillance for all entrances and exits

• Electronic access control

- for dedicated root server, colocation server, cloud server and storage box principal commissions
- server passwords, which, after the initial deployment, can only

CERTIFICATE

This is to certify that the Information Security Management System of

HETZNER

Hetzner Online GmbH
Industriestraße 25
91710 Gunzenhausen
Germany

at the locations Nuremberg, Falkenstein/Vogtland and Tuusula:

Hetzner Online GmbH
Sigmundstraße 135
90431 Nuremberg
Germany

Hetzner Online GmbH
Am Datacenter-Park
08223 Falkenstein/Vogtland
Germany

Hetzner Online GmbH
Huurrekuja 10
04360 Tuusula
Finland

with the scope of

"The scope of the information security management system includes the infrastructure, operation and customer support of the data center."

has been assessed and registered by FOX Certification GmbH and found to be in compliance with the requirements of

ISO/IEC 27001:2013

This verification is subjected to the company maintaining its system to the required standard, which will be monitored by FOX Certification. This certificate is valid for 3 years to satisfactory maintenance of the management system as per the standard.